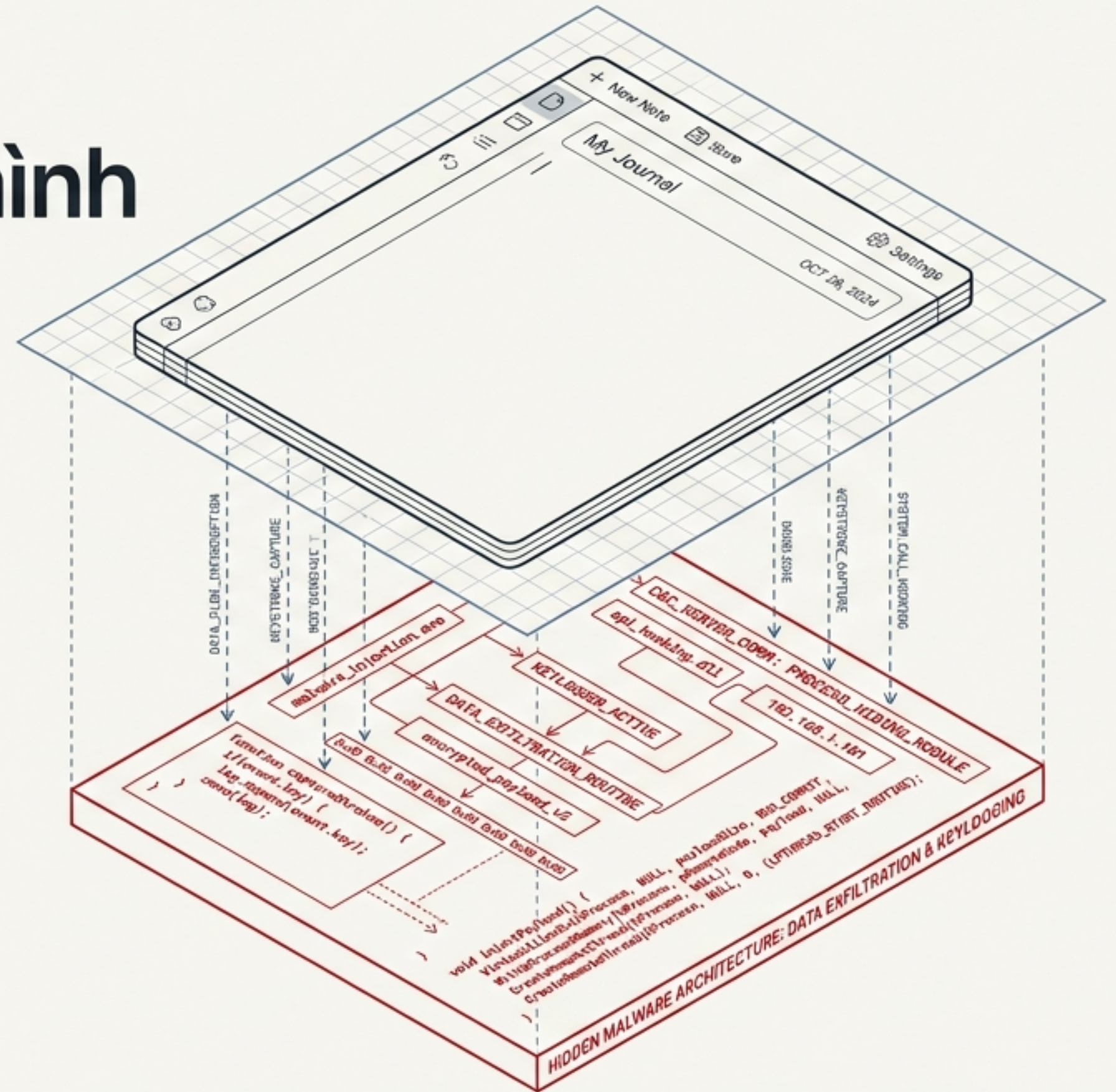


Bóc tách "Papa Note": Giải phẫu Mã độc Ẩn mình và Cơ chế Phòng thủ Bàn phím Ảo

Mô hình thực nghiệm (PoC) chứng minh
vòng đời của mã độc nguy trang dưới lớp
vỏ phần mềm hợp pháp.



4 Trụ cột Cốt lõi của Chiến dịch Tình báo Không gian mạng



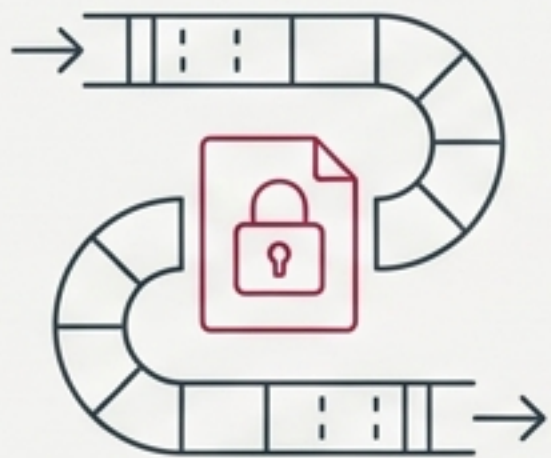
Đánh chặn (Interception)

Thu thập toàn cục tín hiệu
phím bấm hệ thống.



Nhận diện Ngữ cảnh (Context-Awareness)

Xác định mục tiêu giá trị cao
(Banking, Social Media).



Chuyển giao Dữ liệu (Exfiltration)

Tuồn dữ liệu ra ngoài qua
kênh truyền tải không
đồng bộ.

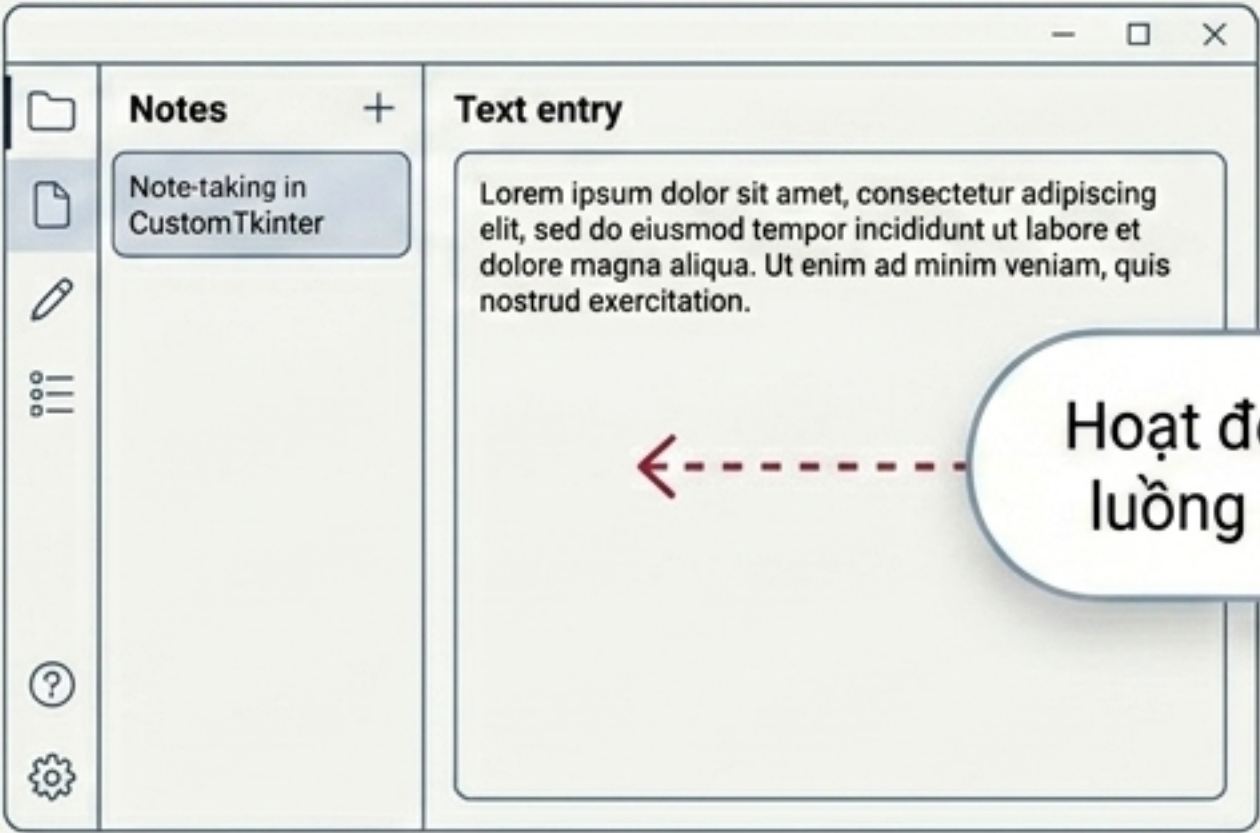


Phòng thủ (Anti-Keylogger)

Vô hiệu hóa Hooking vật lý
thông qua tương tác GUI.

Kiến trúc Kép: Sự lừa dối hoàn hảo dưới vỏ bọc một ứng dụng hợp pháp

Frontend Hợp pháp



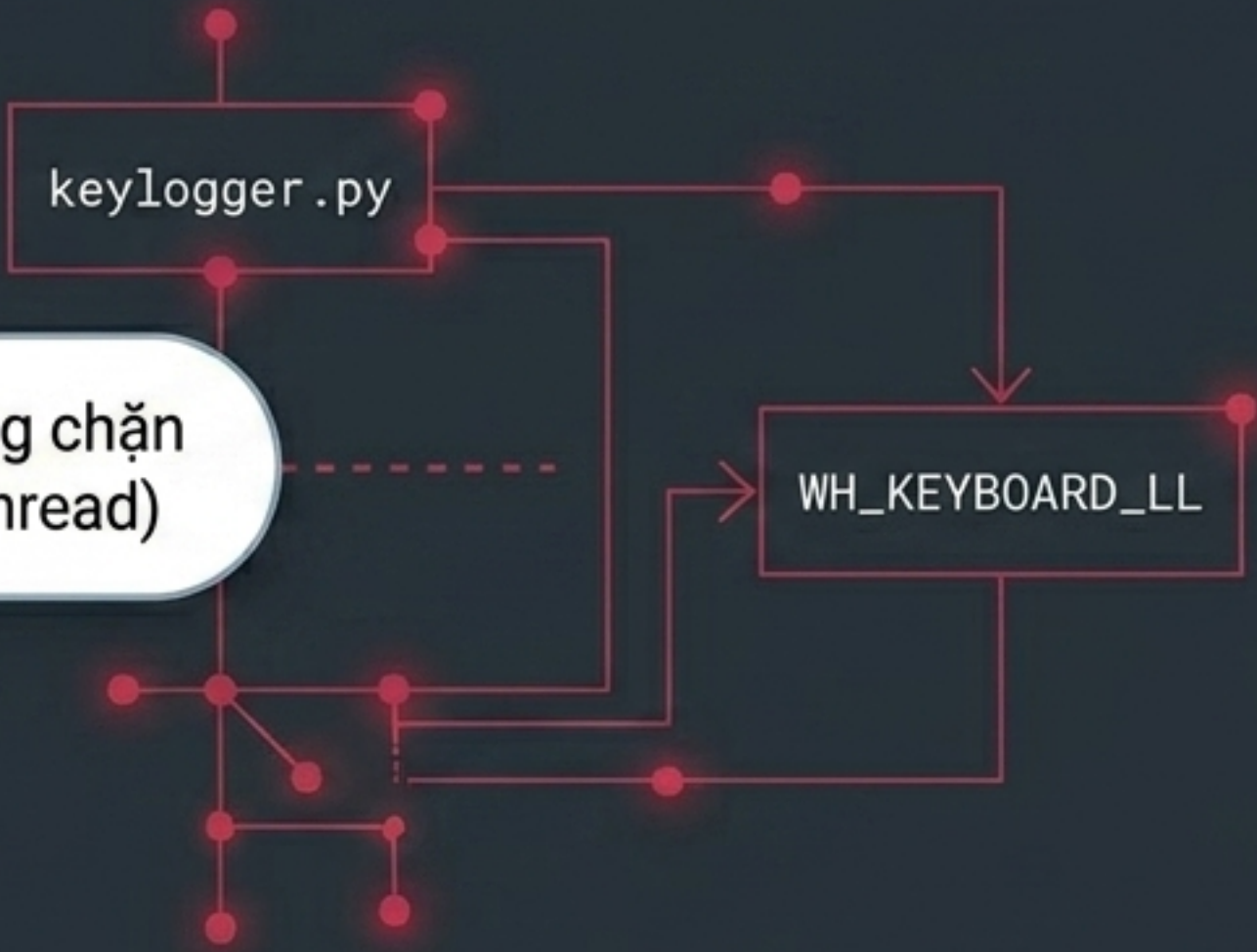
Legitimate User Interface



SQLite (notes.db)

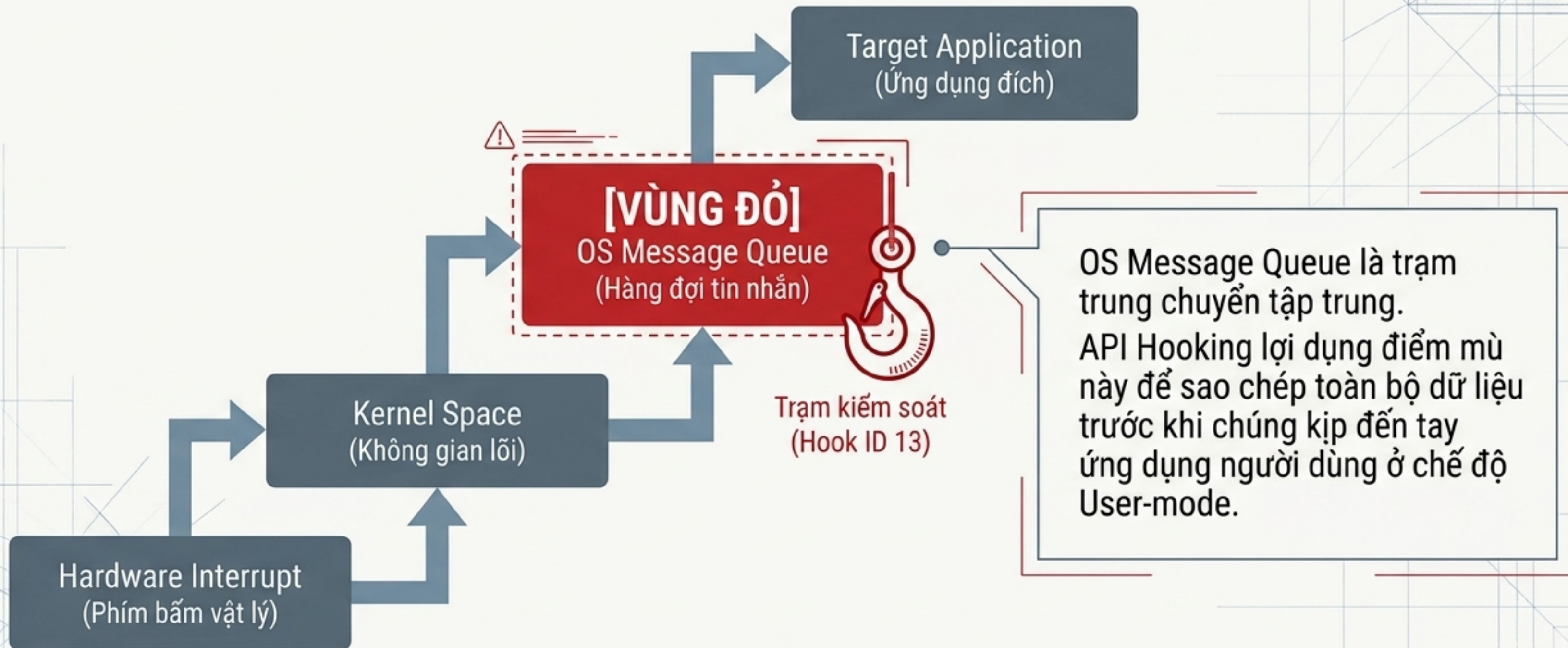
Hoạt động song song, không chặn
luồng giao diện chính (UI thread)

Backend Mã độc



Malicious Daemon Thread

Lỗ hổng Cấu trúc OS và Vị trí Thiết lập Trạm Đánh chặn



Triển khai Low-Level Hooking và Tính tất yếu của Đa luồng

1 Khai thác WH_KEYBOARD_LL qua Win32 API

```
import keyboard

# ...

WH_KEYBOARD_LL = 13

def on_press(key):
    # ... ghi nhận ...

def start_keylogger():
    # ...
    hook = keyboard.hook(WH_KEYBOARD_LL)

    # ...
    # Threading setup
    thread = threading.Thread(target=start_keylogger, daemon=True)
    thread.start()

# ...

if __name__ == '__main__':
    # ...
```

2

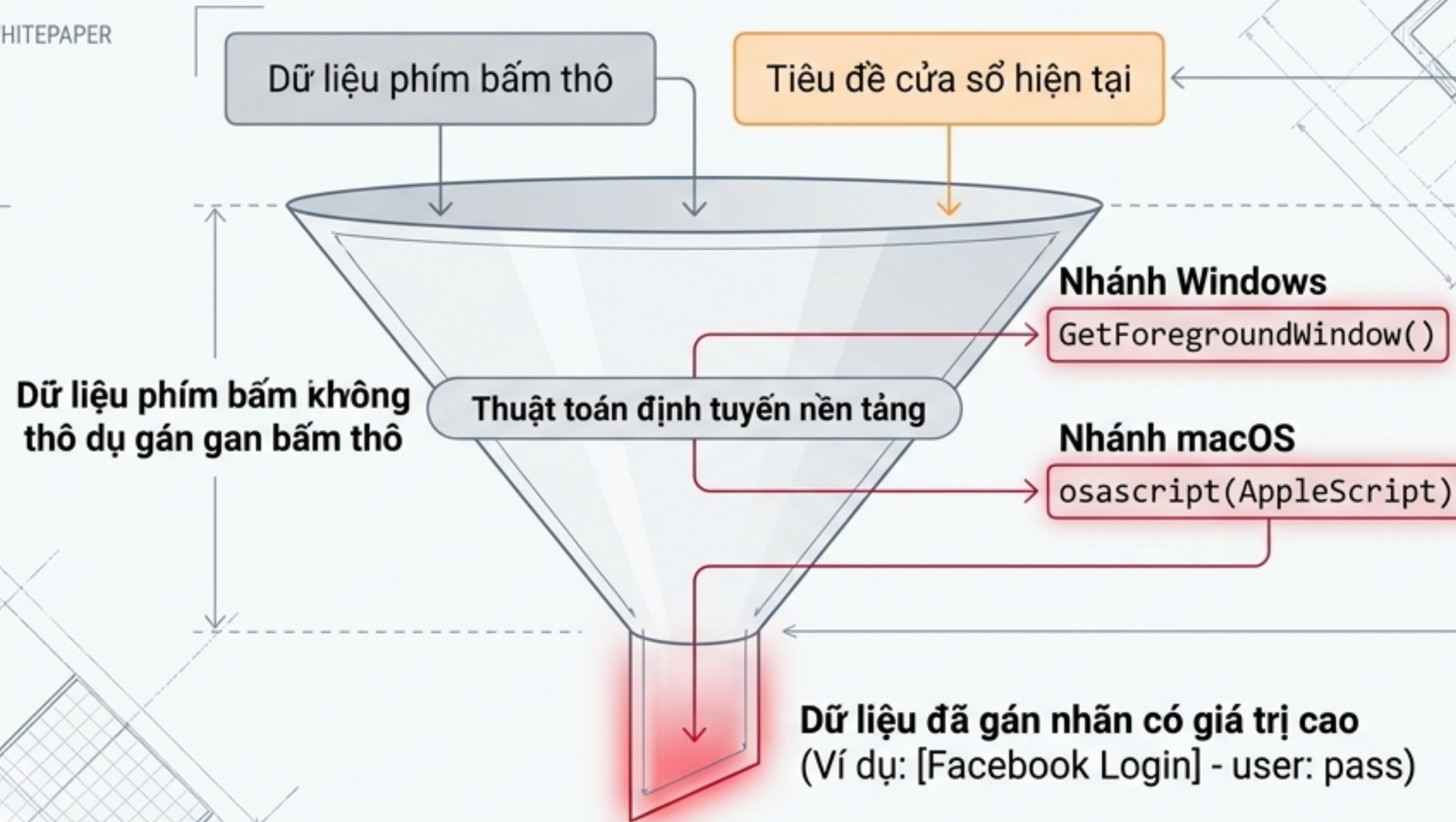
Luồng Daemon bất đồng bộ (Asynchronous Daemon Thread) - Bắt buộc phải có để giữ cho giao diện UI luôn mượt mà, ngăn nản nhân sinh nghi.

3

Hệ thống ghi nhận từng chuyển trạng thái của phím bấm, bao gồm cả tín hiệu điều khiển đặc biệt.

Bộ lọc Ngữ cảnh: Biến dữ liệu phím bấm thô thành Thông tin Tình báo

PREMIUM, FORENSIC ARCHITECTURAL WHITEPAPER



Hàm **get_active_window_title()** cho phép Keylogger lọc bỏ nhiễu và định vị chính xác khoảng khắc nạn nhân truy cập các mục tiêu giá trị cao.

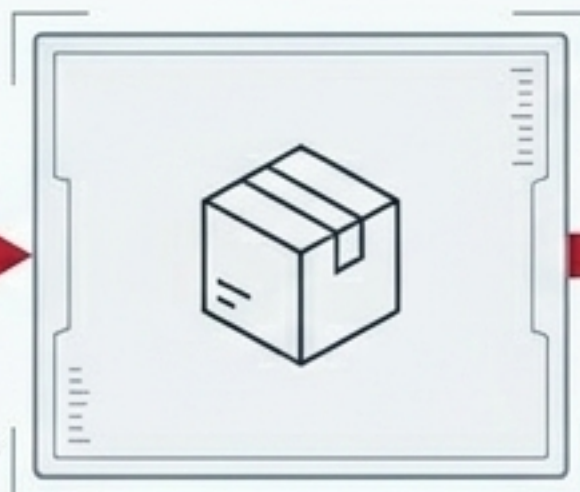
Xuyên thủng Tường lửa: Kênh Chuyển giao Dữ liệu Ngụy trang

Tại sao lại là SMTP?

Traffic mã hóa StartTLS đi qua Port 587 hòa trộn hoàn hảo vào lưu lượng mạng doanh nghiệp hợp pháp, dễ dàng qua mặt các quy tắc egress filtering (lọc đầu ra) cơ bản của Tường lửa.



system_logs.txt



Đóng gói MIME



[CỔNG 587 - SMTP/TLS]



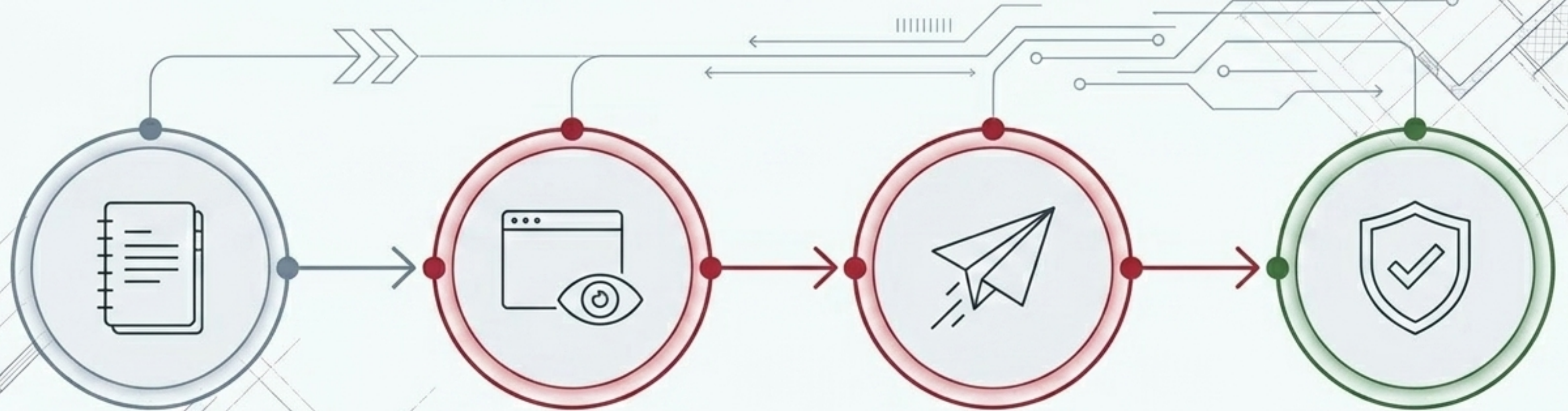
Tự động xóa dấu vết



Tối ưu hóa: REPORT_INTERVAL

Cân bằng giữa giám sát thời gian thực và tránh bị phát hiện bất thường.

Vòng đời của một Cuộc tấn công: Từ Sự lừa dối đến Điểm mù



Bước 1: Sự lừa dối (The Deception)

Khởi tạo "Papa Note", lưu trữ cục bộ bình thường.

Bước 2: Sự phản bội (The Violation)

Nạn nhân lướt web, đăng nhập mạng xã hội; luồng Daemon thu thập log ngầm.

Bước 3: Thu hoạch (The Harvest)

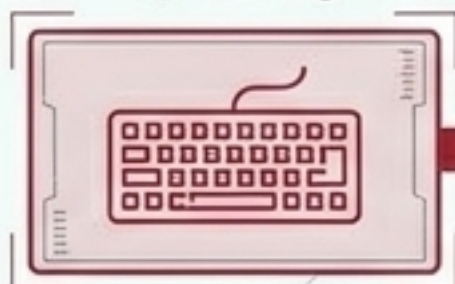
Hệ thống tự động kích hoạt SMTP, gửi gói tình báo về thiết bị của Hacker.

Bước 4: Kiểm chứng Phòng thủ (Defense Verification)

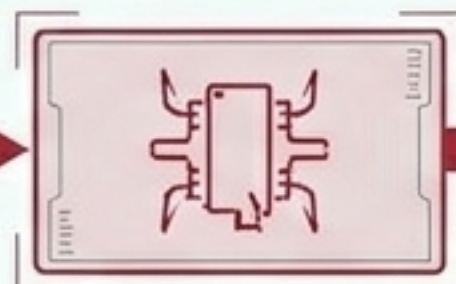
Kích hoạt Security Center. File log hệ thống lập tức TRỐNG.

Lý thuyết Vượt rào: Vô hiệu hóa Hooking bằng Bàn phím Ảo

Path A (Đường màu Đỏ)



Bàn phím vật lý



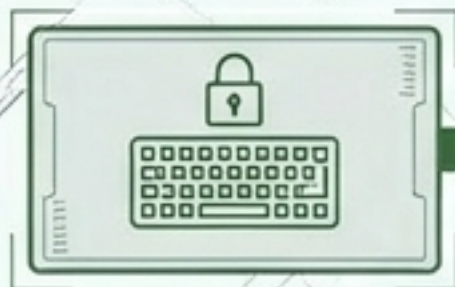
Ngắt phần cứng

Trạm kiểm soát Kernel
(WH_KEYBOARD_LL)



BỊ XÂM PHẠM

Path B (Đường màu Xanh)



Bàn phím Ảo
(Security Center)



GUI Event Loop
(Sự kiện click chuột)



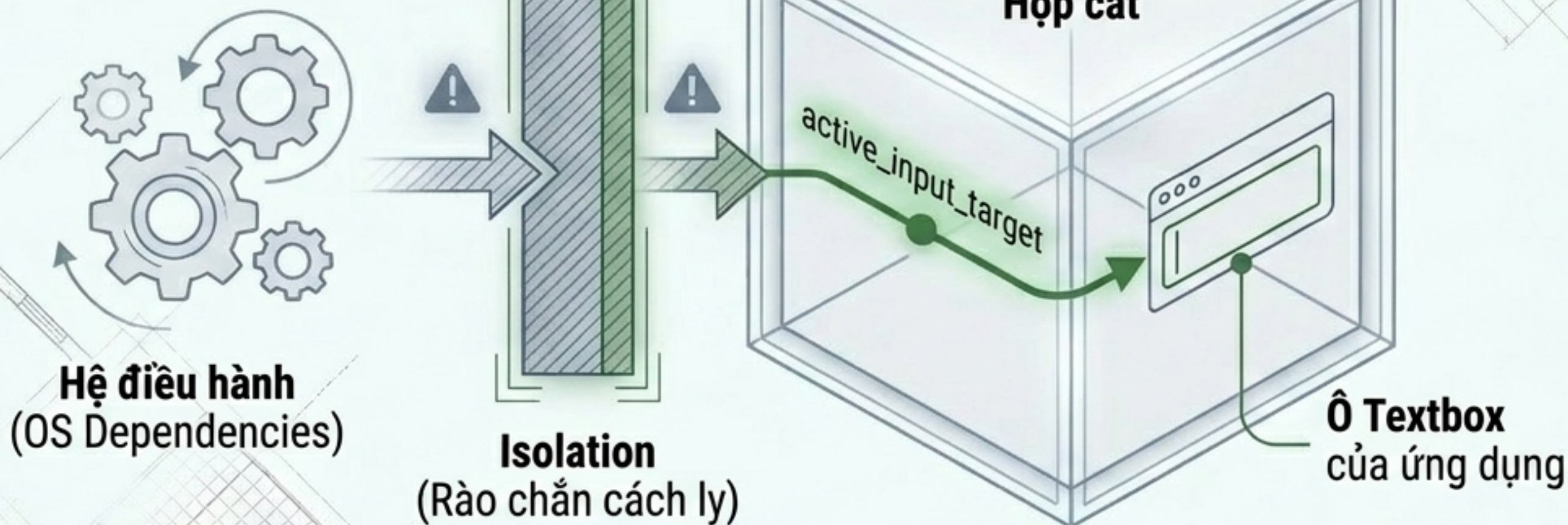
Ứng dụng đích



VƯỢT MẶT HOÀN TOÀN

Bằng cách chuyển đổi hành vi **Nhập liệu (Keystroke)** thành **Hành vi Chuột (Mouse Events)**, Bàn phím ảo hoàn toàn né tránh không gian theo dõi bàn phím của Kernel.

Kiến trúc Trusted Sandbox: Bơm Dữ liệu Trực tiếp vào Bộ nhớ



Cơ chế nội bộ kiểm soát vị trí con trỏ chuột, từ đó "bơm" trực tiếp các chuỗi ký tự đã được mã hóa vào bộ nhớ của ứng dụng. Mọi tương tác hoàn toàn độc lập với OS Keyboard Queue.

Ma trận Đánh giá Nhập liệu: Bàn phím Vật lý vs. Bàn phím Ảo

Chiều đánh giá	Bàn phím Vật lý	Bàn phím Ảo
Đường dẫn I/O (I/O Pathway)	Phụ thuộc OS Kernel	Truyền tải qua Mouse Events
Khả năng bị Hooking	Cực kỳ dễ bị Hook 	Vô hình trước Keyboard Hook 
Trải nghiệm người dùng	Trải nghiệm nhanh, thuận tiện 	Trải nghiệm chậm, kém tự nhiên 
Điểm mù bảo mật	Mọi tiến trình ngấm	Screen-scraping, Mouse-tracking

Không gian Mối đe dọa Mở rộng: Điểm mù và Hạn chế cốt lõi

Screen-scraping Malware

Mã độc chụp màn hình có thể "nhìn thấy" người dùng click vào phím ảo nào.

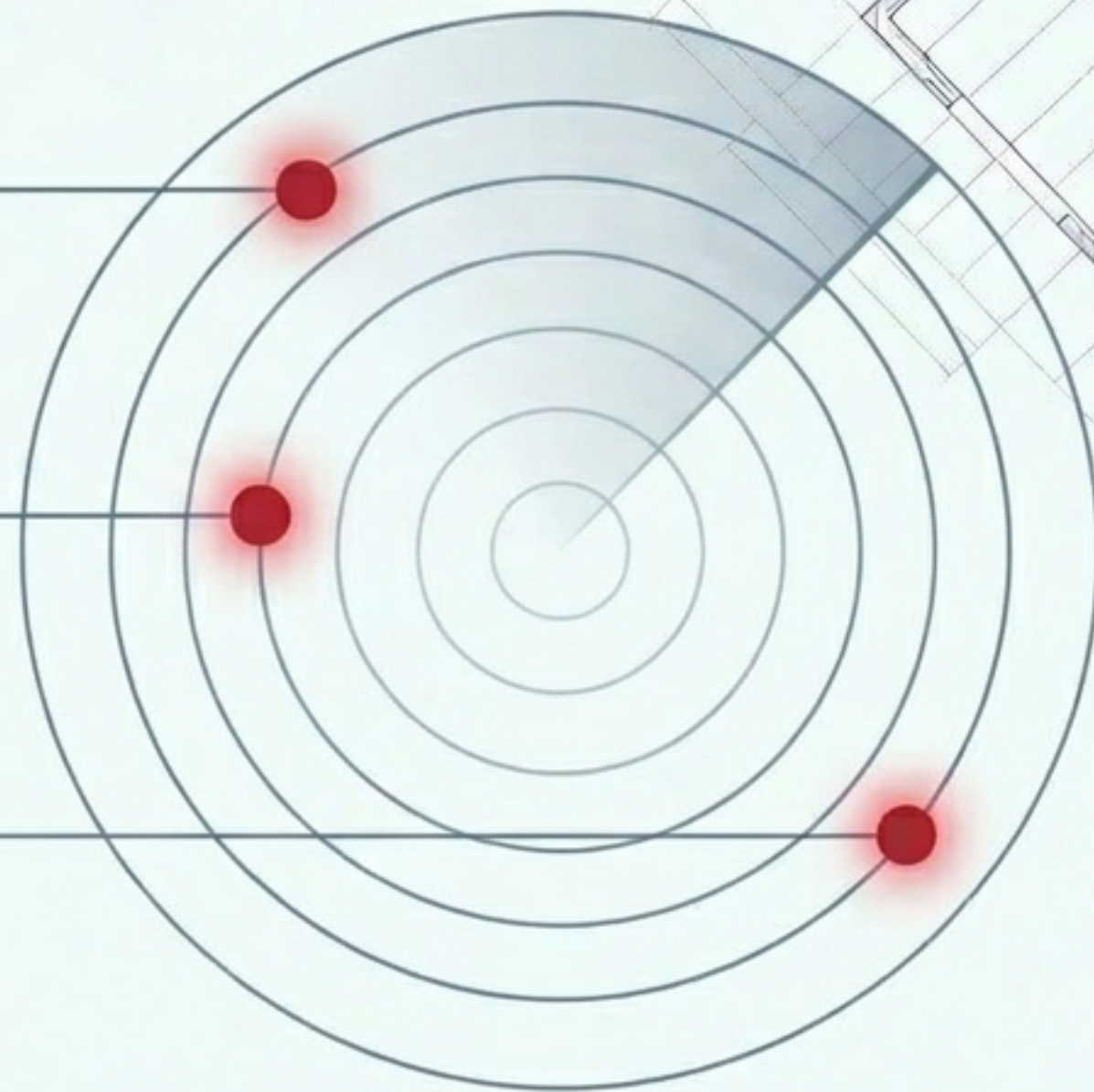
Mouse-tracking Telemetry

Ghi nhận tọa độ X-Y của chuột để dịch ngược ra phím bấm.

Antivirus Heuristics

Global Hooking Pattern của "Papa Note" có thể bị các AV hiện đại phát hiện dựa trên phân tích hành vi.

Radar Scan



Định hướng tương lai: Nâng cấp lớp bảo vệ Database bằng kỹ thuật mã hóa băm mật khẩu bcrypt thay vì lưu trữ Plain-text.

Cán cân Bảo mật: Sự đánh đổi mong manh giữa Tiện dụng và An toàn

Sự Tiện Dụng

Gõ phím vật lý nhanh, nhưng rủi ro lộ lọt cao.



Sự Bảo Mật

Bàn phím ảo an toàn, nhưng giảm hiệu suất nhập liệu.

Papa Note chứng minh rằng việc giảm thiểu hoàn toàn rủi ro đòi hỏi hệ thống **phòng thủ đa lớp**: từ phân tích hành vi, cách ly bộ nhớ, đến mã hóa dữ liệu lỗi.

Dự án phát triển độc quyền phục vụ mục đích nghiên cứu học thuật tại Đại học Tôn Đức Thắng. Nghiêm cấm triển khai trái phép.